

TP1 : Le festival PDO et Sessions

Le site comporte un espace public pour consulter les artistes et un espace administrateur pour les gérer. Vous allez découvrir **PDO**, l'extension de PHP qui dialogue avec une base de données MySQL, et réutiliser les **sessions** du TD2.

Trois objectifs : lire des données avec PDO, protéger une page avec une session et ajouter un artiste avec une requête préparée.

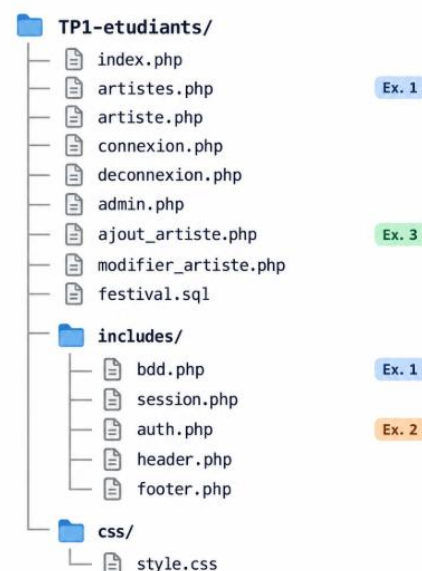
Ce qui est fourni

Fichiers	Votre travail
<code>index.php</code> , <code>includes/header.php</code> , <code>includes/footer.php</code> , CSS	Aucun : accueil et navigation assemblés
<code>includes/bdd.php</code>	À compléter
<code>artistes.php</code>	À compléter
<code>artiste.php</code>	Aucun : fiche et liens fournis
<code>connexion.php</code> , <code>deconnexion.php</code> , <code>includes/session.php</code>	Repérer les lignes liées à la session
<code>includes/auth.php</code>	À compléter
<code>admin.php</code>	Aucun : liste de gestion et modification fournies
<code>ajout_artiste.php</code>	À compléter
<code>festival.sql</code>	Importer la base

Installation

- Démarrez Apache et MySQL dans XAMPP.
- Copiez le dossier `TP1-etudiants` dans `C:\xampp\htdocs\r312\` et renommez-le `tp1`.
- Importez `festival.sql` dans phpMyAdmin. **L'import recrée la base festival et efface les ajouts précédents.**
- Repérez `id`, `nom`, `genre`, `pays` dans la table `artiste`. La table `utilisateur` contient déjà le compte administrateur : observez son `login`, son rôle et son mot de passe haché. Les tables `scene` et `passage` ne servent qu'au bonus.

Arborescence du dossier fourni



5. Ouvrez `http://localhost/r312/tp1/index.php` ; adaptez le port si nécessaire.
6. Dans `index.php`, repérez les inclusions du header et du footer. **Le code commun évite de répéter la navigation sur chaque page.**

Exercice 1 : Afficher les artistes

1. Se connecter

Dans `includes/bdd.php`, remplacez `A_COMPLETER` par `festival`. Le login MySQL et son mot de passe sont les deux paramètres juste en dessous, déjà renseignés pour XAMPP : `root` et une chaîne vide. Ces identifiants de connexion à MySQL n'ont rien à voir avec le compte administrateur du site.

Si une page affiche ensuite un pavé `Fatal error : Uncaught PDOException`, lisez bien le message : `Unknown database` signale un nom de base mal écrit, `Connection refused` invite à vérifier que MySQL est démarré et que l'hôte et le port sont corrects. L'option `ERRMODE_EXCEPTION` demande à PDO de signaler ses erreurs par une exception ; c'est le comportement par défaut depuis PHP 8, et `bdd.php` le rend explicite.

Dans `artistes.php`, au TODO 1.1, chargez la connexion :

```
require __DIR__ . '/includes/bdd.php';
```

`$pdo` représente la connexion à MySQL. `__DIR__` désigne le dossier du fichier courant.

2. Lire les données

Au TODO 1.2, remplacez `$artistes = []` ; par deux instructions : exécuter le SELECT, puis récupérer toutes ses lignes.

Requête à utiliser :

```
SELECT id, nom, genre, pays FROM artiste ORDER BY nom
```

Modèle :

```
$requete = $pdo->query('votre requête SQL');  
$artistes = $requete->fetchAll();
```

3. Afficher les lignes

Au TODO 1.3, remplacez `[]` dans la boucle par `$artistes`.

```
foreach ($artistes as $artiste):
```

Le HTML de chaque ligne, les liens et la fin de boucle sont fournis. Repérez :

- `$artistes` : la liste complète ;
- `$artiste` : l'artiste de la ligne en cours ;
- `htmlspecialchars()` : affiche le contenu comme du texte dans le HTML.

Rechargez la page. Cliquez sur Shreya Ghoshal : sa fiche doit afficher Inde et Musique du monde. Le lien et la fiche fonctionnent déjà ; vous n'avez pas à les programmer.

4. Trois panes à analyser

Si vous avez de l'avance. Cette activité ne doit pas retarder l'exercice 2. Votre liste marche : cassez-la maintenant, exprès. Savoir lire un message d'erreur vaut plus cher que savoir écrire la ligne juste, et c'est la seule compétence que personne ne peut copier-coller à votre place. Remettez la ligne d'origine après chaque essai.

Panne 1 — la connexion n'a pas été chargée. Mettez `//` devant le `require` de `bdd.php`. Vous obtenez :

```
Warning: Undefined variable $pdo
Fatal error: Uncaught Error: Call to a member function query() on null
```

Panne 2 — vous parcourez une ligne au lieu de la liste. Dans la boucle, écrivez `$artiste` au lieu de `$artistes`. Vous obtenez :

```
Warning: Undefined variable $artiste
Warning: foreach() argument must be of type array|object, null given
```

Panne 3 — la colonne n'existe pas. Dans le SELECT, écrivez `nomm` au lieu de `nom`. Vous obtenez :

```
Fatal error: Uncaught PDOException: SQLSTATE[42S22]:
Column not found: 1054 Unknown column 'nomm' in 'field list'
```

A retenir de ces essais :

1. **Lisez le premier message, pas le dernier.** Dans la panne 1, le `Fatal error` n'est que la conséquence ; la cause est le `Warning` juste au-dessus.
2. **Une page qui s'affiche n'est pas une page qui marche.** La panne 2 renvoie un code 200 et un tableau vide : c'est la panne la plus dangereuse, parce qu'elle ne ressemble pas à une panne.
3. **Repérez qui se plaint.** Une `PDOException` signale une erreur remontée par PDO, et `SQLSTATE` en donne la catégorie côté base ; `Undefined variable` vient de PHP. Le message indique aussi le fichier et la ligne : lisez-les.
4. **Compter.** Affichez « 22 artistes programmés » au-dessus du tableau. `count($artistes)` fonctionne.

Exercice 2 : Connexion de l'administrateur et protection

Le formulaire et le traitement de connexion sont fournis. L'import de `festival.sql` a créé le compte **admin / Festival2027!** dans la table `utilisateur`, avec le rôle `admin`. Vous n'avez ni inscription ni authentification à programmer.

Dans phpMyAdmin, ouvrez la table `utilisateur`. La colonne `mot_de_passe` ne contient pas le texte `Festival2027!` mais une empreinte de 60 caractères commençant par `$2y$`, produite par `password_hash()`. Un mot de passe ne s'enregistre jamais en clair.

Dans `connexion.php`, repérez:

```
$requete = $pdo->prepare(
    'SELECT id, login, mot_de_passe, role FROM utilisateur WHERE login = :login'
);
$requete->execute(['login' => $login]);
```

```
$utilisateur = $requete->fetch();

if ($utilisateur && password_verify($motDePasse, $utilisateur['mot_de_passe'])) {
    $_SESSION['login'] = $utilisateur['login'];
    $_SESSION['role'] = $utilisateur['role'];
}
```

1. Une requête préparée cherche le compte à partir du login saisi ; `fetch()` renvoie `false` si ce login n'existe pas.
2. `password_verify()` compare le mot de passe saisi à l'empreinte lue en base. Cette comparaison se fait en PHP, jamais en SQL : `password_hash()` produit une empreinte différente à chaque appel, on ne peut donc pas la recalculer pour l'écrire dans un `WHERE`.
3. Le login et le rôle sont enregistrés côté serveur, dans la session. `includes/session.php` démarre la session avant tout HTML.

Dans `includes/auth.php`, au `TODO 2.1`, remplacez les deux instructions provisoires `http_response_code(503)` et `exit(...)` par un contrôle :

1. Si `$_SESSION['login']` n'existe pas, rediriger vers `connexion.php`.
2. Après cette redirection, terminer le script avec `exit`.
3. Sinon, laisser la page continuer jusqu'au contrôle du rôle placé juste en dessous. Ce bloc est fourni et porte la mention « NE PAS MODIFIER » : il refuse l'accès si le rôle enregistré en session n'est pas `admin`. Tant que les deux lignes provisoires sont là, il n'est jamais atteint.

Le fichier `auth.php` est déjà chargé au début de `admin.php`, `ajout_artiste.php` et `modifier_artiste.php`. Chaque page de gestion vérifie ainsi l'accès, même si on tape son adresse directement.

Exercice 3 : Ajouter un artiste

Dans `ajout_artiste.php`, le formulaire, la lecture des champs et leurs vérifications sont fournis. Le code suit trois étapes : lire les champs, vérifier les valeurs, enregistrer si aucune erreur n'a été trouvée.

Au commentaire `TODO 3.1` :

1. Chargez `includes/bdd.php`.
2. Préparez la requête et transmettez les valeurs :

```
$requete = $pdo->prepare(
    'INSERT INTO artiste (nom, genre, pays) VALUES (:nom, :genre, :pays)'
);
$requete->execute([
    'nom' => $nom,
    'genre' => $genre,
    'pays' => $pays,
]);
```

3. Remplacez le message provisoire par le retour à l'administration :

```
header('Location: admin.php');  
exit;
```

Les valeurs sont séparées du texte SQL. L'identifiant est créé automatiquement par MySQL. Le nom est obligatoire ; les champs facultatifs peuvent rester vides.

Ajoutez un artiste de votre choix. Retrouvez-le dans la gestion et dans la liste publique. La redirection évite de renvoyer le formulaire en rechargeant la page de résultat.

Le champ caché `csrf` et sa vérification sont fournis pour protéger les formulaires. Conservez-les ; ils ne font pas partie du travail à réaliser.

Dépôt du travail :

Déposez `Nom_Prenom_TP1.zip` avec votre projet